

RISK ASSESSMENT	RA-1	RA-1	RISK ASSESSMENT POLICY AND PROCEDURES	The organization:
RISK ASSESSMENT	RA-1	RA-1a	RISK ASSESSMENT POLICY AND PROCEDURES	Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]:
RISK ASSESSMENT	RA-1	RA-1a.1	RISK ASSESSMENT POLICY AND PROCEDURES	A risk assessment policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
RISK ASSESSMENT	RA-1	RA-1a.2	RISK ASSESSMENT POLICY AND PROCEDURES	Procedures to facilitate the implementation of the risk assessment policy and associated risk assessment controls; and
RISK ASSESSMENT	RA-1	RA-1b	RISK ASSESSMENT POLICY AND PROCEDURES	Reviews and updates the current:
RISK ASSESSMENT	RA-1	RA-1b.1	RISK ASSESSMENT POLICY AND PROCEDURES	Risk assessment policy [Assignment: organization-defined frequency]; and
RISK ASSESSMENT	RA-1	RA-1b.2	RISK ASSESSMENT POLICY AND PROCEDURES	Risk assessment procedures [Assignment: organization-defined frequency].
RISK ASSESSMENT	RA-2	RA-2	SECURITY CATEGORIZATION	The organization:
RISK ASSESSMENT	RA-2	RA-2a	SECURITY CATEGORIZATION	Categorizes information and the information system in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance;
RISK ASSESSMENT	RA-2	RA-2b	SECURITY CATEGORIZATION	Documents the security categorization results (including supporting rationale) in the security plan for the information system; and

RISK ASSESSMENT	RA-2	RA-2c	SECURITY CATEGORIZATION	Ensures that the authorizing official or authorizing official designated representative reviews and approves the security categorization decision.
RISK ASSESSMENT	RA-3	RA-3	RISK ASSESSMENT	The organization:
RISK ASSESSMENT	RA-3	RA-3a	RISK ASSESSMENT	Conducts an assessment of risk, including the likelihood and magnitude of harm, from the unauthorized access, use, disclosure, disruption, modification, or destruction of the information system and the information it processes, stores, or transmits;
RISK ASSESSMENT	RA-3	RA-3b	RISK ASSESSMENT	Documents risk assessment results in [Selection: security plan; risk assessment report; [Assignment: organization-defined document]];
RISK ASSESSMENT	RA-3	RA-3c	RISK ASSESSMENT	Reviews risk assessment results [Assignment: organization-defined frequency];
RISK ASSESSMENT	RA-3	RA-3d	RISK ASSESSMENT	Disseminates risk assessment results to [Assignment: organization-defined personnel or roles]; and

RISK ASSESSMENT	RA-3	RA-3e	RISK ASSESSMENT	Updates the risk assessment [Assignment: organization-defined frequency] or whenever there are significant changes to the information system or environment of operation (including the identification of new threats and vulnerabilities), or other conditions that may impact the security state of the system.
RISK ASSESSMENT	RA-4	RA-4	RISK ASSESSMENT UPDATE	[Withdrawn: Incorporated into RA-3].
RISK ASSESSMENT	RA-5	RA-5	VULNERABILITY SCANNING	The organization:
RISK ASSESSMENT	RA-5	RA-5a	VULNERABILITY SCANNING	Scans for vulnerabilities in the information system and hosted applications [Assignment: organization-defined frequency and/or randomly in accordance with organization-defined process] and when new vulnerabilities potentially affecting the system/applications are identified and reported;
RISK ASSESSMENT	RA-5	RA-5b	VULNERABILITY SCANNING	Employs vulnerability scanning tools and techniques that facilitate interoperability among tools and automate parts of the vulnerability management process by using standards for:
RISK ASSESSMENT	RA-5	RA-5b.1	VULNERABILITY SCANNING	Enumerating platforms, software flaws, and improper configurations;

RISK ASSESSMENT	RA-5	RA-5b.2	VULNERABILITY SCANNING	Formatting checklists and test procedures; and
RISK ASSESSMENT	RA-5	RA-5b.3	VULNERABILITY SCANNING	Measuring vulnerability impact;
RISK ASSESSMENT	RA-5	RA-5c	VULNERABILITY SCANNING	Analyzes vulnerability scan reports and results from security control assessments;
RISK ASSESSMENT	RA-5	RA-5d	VULNERABILITY SCANNING	Remediates legitimate vulnerabilities [Assignment: organization-defined response times] in accordance with an organizational assessment of risk; and
RISK ASSESSMENT	RA-5	RA-5e	VULNERABILITY SCANNING	Shares information obtained from the vulnerability scanning process and security control assessments with [Assignment: organization-defined personnel or roles] to help eliminate similar vulnerabilities in other information systems (i.e., systemic weaknesses or deficiencies).
RISK ASSESSMENT	RA-5 (1)	RA-5 (1)	UPDATE TOOL CAPABILITY	The organization employs vulnerability scanning tools that include the capability to readily update the information system vulnerabilities to be scanned.

RISK ASSESSMENT	RA-5 (2)	RA-5 (2)	UPDATE BY FREQUENCY / PRIOR TO NEW SCAN / WHEN IDENTIFIED	The organization updates the information system vulnerabilities scanned [Selection (one or more): [Assignment: organization-defined frequency]; prior to a new scan; when new vulnerabilities are identified and reported].
RISK ASSESSMENT	RA-5 (3)	RA-5 (3)	BREADTH / DEPTH OF COVERAGE	The organization employs vulnerability scanning procedures that can identify the breadth and depth of coverage (i.e., information system components scanned and vulnerabilities checked).
RISK ASSESSMENT	RA-5 (4)	RA-5 (4)	DISCOVERABLE INFORMATION	The organization determines what information about the information system is discoverable by adversaries and subsequently takes [Assignment: organization-defined corrective actions].
RISK ASSESSMENT	RA-5 (5)	RA-5 (5)	PRIVILEGED ACCESS	The information system implements privileged access authorization to [Assignment: organization-identified information system components] for selected [Assignment: organization-defined vulnerability scanning activities].
RISK ASSESSMENT	RA-5 (6)	RA-5 (6)	AUTOMATED TREND ANALYSES	The organization employs automated mechanisms to compare the results of vulnerability scans over time to determine trends in information system vulnerabilities.
RISK ASSESSMENT	RA-5 (7)	RA-5 (7)	AUTOMATED DETECTION AND NOTIFICATION OF UNAUTHORIZED COMPONENTS	[Withdrawn: Incorporated into CM-8].

RISK ASSESSMENT	RA-5 (8)	RA-5 (8)	REVIEW HISTORIC AUDIT LOGS	The organization reviews historic audit logs to determine if a vulnerability identified in the information system has been previously exploited.
RISK ASSESSMENT	RA-5 (9)	RA-5 (9)	PENETRATION TESTING AND ANALYSES	[Withdrawn: Incorporated into CA-8].
RISK ASSESSMENT	RA-5 (10)	RA-5 (10)	CORRELATE SCANNING INFORMATION	The organization correlates the output from vulnerability scanning tools to determine the presence of multi-vulnerability/multi-hop attack vectors.
RISK ASSESSMENT	RA-6	RA-6	TECHNICAL SURVEILLANCE COUNTERMEASURES SURVEY	The organization employs a technical surveillance countermeasures survey at [Assignment: organization-defined locations] [Selection (one or more): [Assignment: organization-defined frequency]; [Assignment: organization-defined events or indicators occur]].